How to spot and report phishing emails

Article KB0010081 | Owner: Security Operations | Subcategory: Phishing report | Applies to: Windows 11 (22H2/23H2/24H2), macOS 14/15, Outlook desktop (Windows/Mac), Outlook on the web, Mobile Outlook app

Summary

This article teaches Acme Global employees how to recognise typical phishing cues, safely report suspicious messages using Outlook's built-in Report feature, and what steps the Service Desk and Security Operations teams take to remediate confirmed phishing attempts. It also outlines what to do if you have already clicked a link or entered credentials.

Symptoms

- Unexpected sender address that does not match the display name or uses a look-alike domain (e.g., @acme-support.com instead of @acme.example)
- Urgent or threatening language demanding immediate action (e.g., "Your account will be closed in 24 hours")
- Poor grammar, spelling mistakes, or odd phrasing atypical of legitimate Acme communications
- Attachments with unexpected file types (.zip, .exe, .scr) or invoices you were not expecting
- Embedded URLs that, when hovered, show a different destination than the displayed text (often a misspelled or non-Acme domain)
- Requests for username, password, OTP, or other credentials via email or a linked login page

Common causes

- Attackers spoofing Acme domains or using look-alike domains to impersonate trusted senders
- Compromised employee accounts used to launch internal phishing campaigns
- Social-engineering tactics that exploit urgency, authority, or curiosity to bypass judgment
- Malicious attachments or links designed to harvest credentials or deliver malware

Recognizing Common Phishing Indicators

Phishing messages often try to mimic legitimate Acme correspondence but contain subtle clues. Look for mismatched sender addresses, urgent language that pressures you to act quickly, and spelling or grammatical errors that would be unusual in official communications. Unexpected attachments-especially executable files-or invoices you did not anticipate are also red flags. Finally, hover over any link to see the true destination; if the URL does not belong to an Acme domain or looks misspelled, treat the message as suspicious.

Self-Help: How to Report a Suspicious Email

If you receive an email that matches any of the indicators above, do not click any links or open attachments. Use Outlook's built-in reporting function to alert Security Operations, then remove the message from your mailbox. This helps the team block the sender and prevent others from seeing the same lure.

1. Do not click any links or open any attachments in the suspicious message.
2. In Outlook desktop (Windows or Mac): select the message, click the "Report Message" button on the ribbon, and choose "Phishing".
3. In Outlook on the web: open the message, click the three-dot (---) menu, select "Report", then choose "Phishing".
4. Alternatively, forward the email as an attachment to <phishing@acme.example> and then delete the original from your Inbox and Deleted Items folder.
5. If you have already clicked a link, opened an attachment, or entered credentials, follow the guidance in article KB0010082 ("What to do after a possible phishing click") and inform the Service Desk immediately.

Service Desk Agent Procedure

When a ticket arrives reporting a suspected phishing email, the Service Desk follows a structured workflow to verify, remediate, and communicate outcomes. Agents should first gather the necessary evidence, then use the available tools to purge the threat and block the source. If the user has interacted with the content, additional credential-protection steps are required.

1. Open the ticket and confirm the user's description; ask for the original email headers if they are not attached.

2. Using Exchange Online PowerShell or the Security & Compliance centre, search all mailboxes for the message (e.g., Search-Mailbox -Identity * -SearchQuery "Subject:'<suspected subject>'").
3. Purge the located copies with Search-Mailbox -DeleteContent or via the Purge option in the compliance portal.
4. Block the sender's domain or IP address in the Exchange Online anti-phishing policy and add the offending URL to the Safe Links block list.
5. If the user reported clicking a link or entering credentials: trigger a self-service password reset, revoke all refresh tokens via Azure AD, and review sign-in logs for risky activity.
6. Notify the user of the actions taken and remind them to use the Report Message button for any future suspicions.
7. Close the ticket with an appropriate outcome: "Email confirmed phishing - purged and sender blocked" or "Legitimate email - released and user notified".

Verification and Follow-Up

After remediation, it is important to confirm that the threat has been fully removed and that any compromised accounts are secured. This step also creates a record for threat-intelligence purposes and provides the user with reassurance and further guidance.

1. Run a follow-up search across all mailboxes to ensure no remnants of the message remain.
2. Verify that the sender block is active in the anti-phishing policy and that the URL appears in the Safe Links block list.
3. For credential-compromise cases, confirm that the password reset succeeded and that the user is prompted for MFA on the next sign-in.
4. Log the incident in the Security Operations threat-intelligence repository and, if warranted, create an indicator of compromise (IOC) for future detection.
5. Inform the user that their mailbox is clean, provide a reminder on phishing awareness, and close the ticket.

When to escalate

If the user indicates they have clicked a link, opened an attachment, or entered credentials, the Service Desk agent must escalate the ticket immediately to the Security Operations group. Include the full email headers, any clicked URLs, the timestamp of interaction, and a summary of actions already taken (e.g., password reset, token revocation). For reports where no interaction occurred, the agent can resolve the ticket using the standard purge-and-block procedure without escalation.

Keywords: phishing, suspicious email, report phishing, Outlook Report Message, fake invoice, credential harvesting, spoofed domain, urgent email, malicious attachment, safe links, anti-phishing, password reset, MFA, security operations, service desk